



Conception et mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé

Codjo Fréjus Loïc SANGRONIO

Licence Informatique | Option Sécurité Informatique

24 juin 2026

Encadreur :
Ing. Guy KPEDJO

RansomShield

2026-07-06



[OUVERTURE — 0 :00 | 30 sec]

Monsieur le Président du jury, Mesdames et Messieurs les membres du jury, bonjour.

Je m'appelle Loïc SANGRONIO. Je vais vous présenter aujourd'hui RansomShield : un système de détection et de réponse aux attaques ransomware, dans un environnement contrôlé.

Dix minutes de présentation. Cinq minutes de démonstration live, sur des machines virtuelles réelles. Je serai à votre disposition pour vos questions à la fin.

→ Commençons par un coup d'œil au plan.

- 1 Introduction Générale
- 2 Revue de littérature
- 3 Analyse et Conception
- 4 Réalisation et Résultats
- 5 Conclusion et Perspectives

Sommaire

- 1 Introduction Générale
- 2 Revue de littérature
- 3 Analyse et Conception
- 4 Réalisation et Résultats
- 5 Conclusion et Perspectives

[SOMMAIRE — 0 :30 | 20 sec]
Le fil de cette présentation est simple.
D'abord le pourquoi — le contexte et les objectifs. Ensuite le comment — la conception et la réalisation.
Et enfin le résultat — ce que ça donne concrètement, en démonstration.
→ Commençons par le contexte.

Introduction Générale

2026-07-06

RansomShield
└─ Introduction Générale

Introduction Générale

Contexte

L'évolution rapide du numérique expose les organisations aux ransomwares : des logiciels malveillants qui rendent les données inaccessibles puis exigent une rançon.

- +73 % d'attaques signalées en 2023 (ENISA)
- Délai moyen de détection sans outil dédié : 21 jours
- Coût moyen par attaque : > 1 million de dollars
- Cibles : PME, hôpitaux, administrations, universités

Objectif général

Concevoir et mettre en œuvre un système de détection et de réponse aux attaques ransomware basé sur la surveillance comportementale des fichiers et des processus, avec une console de supervision traçable.

[CONTEXTE — 1 :00 | 45 sec]

Imaginez : vos fichiers se renomment les uns après les autres, les sauvegardes disparaissent, et un message s'affiche — « payez, ou perdez tout ». C'est un ransomware.

L'ENISA a mesuré une hausse de 73 % de ces attaques en 2023. Sans outil dédié, il faut en moyenne 21 jours pour détecter l'incident — et le coût dépasse souvent le million de dollars.

Les cibles ne sont plus seulement les grandes entreprises : les hôpitaux, les PME, les universités sont touchés.

→ Ce contexte soulève une problématique précise.



Constat

Les antivirus classiques détectent les malwares **connus par leur empreinte**. Face aux variantes nouvelles, ils sont aveugles. Sans outil dédié : **21 jours** en moyenne avant détection — les dommages sont souvent irréversibles.

Problème identifié

Aucune solution open-source, **démontrable en conditions réelles**, n'existe pour la détection comportementale multi-plateforme des ransomwares avec contrôle humain.

Défi #1

Variantes inconnues contournent les antivirus par signatures

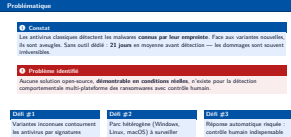
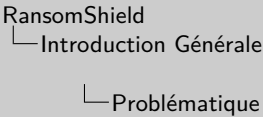
Défi #2

Parc hétérogène (Windows, Linux, macOS) à surveiller

Défi #3

Réponse automatique risquée : contrôle humain indispensable

2026-07-06



[PROBLÉMATIQUE — 1 :45 | 45 sec]
Le problème fondamental : les antivirus classiques détectent par signatures. Un ransomware inconnu passe à travers.
Trois défis structurent ce constat.
Premier défi : les variantes inconnues — il faut détecter le comportement, pas la signature.
Deuxième défi : le parc hétérogène — une organisation réelle gère des machines Windows, Linux, macOS. L'agent doit fonctionner sur toutes les plateformes.
Troisième défi : la réponse automatique est risquée. Couper une machine sans vérification peut paralyser un service. Le contrôle humain n'est pas une contrainte — c'est une garantie.
D'où la question centrale : comment détecter un comportement ransomware, dans un environnement contrôlé, sans déployer de vrai malware ?
→ C'est précisément ce que RansomShield cherche à faire.

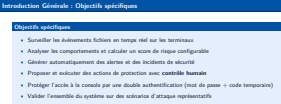
Objectifs spécifiques

- Surveiller les événements fichiers en temps réel sur les terminaux
- Analyser les comportements et calculer un score de risque configurable
- Générer automatiquement des alertes et des incidents de sécurité
- Proposer et exécuter des actions de protection avec **contrôle humain**
- Protéger l'accès à la console par une double authentification (mot de passe + code temporaire)
- Valider l'ensemble du système sur des scénarios d'attaque représentatifs

2026-07-06

RansomShield
└─ Introduction Générale

└─ Introduction Générale : Objectifs spécifiques



[OBJECTIFS — 2 :30 | 35 sec]

Six objectifs concrets.

Un : surveiller les événements fichiers en temps réel. Deux : calculer un score de risque configurable.

Trois : générer automatiquement des alertes et des incidents. Quatre : proposer des actions de protection

— avec un contrôle humain à chaque étape. Cinq : sécuriser la console par une double authentification.

Six : valider l'ensemble sur des scénarios d'attaque réalistes.

→ Pour y répondre, le mémoire s'articule en trois chapitres — voyons d'abord les fondements.

Revue de littérature

2026-07-06

RansomShield
— Revue de littérature

Revue de littérature

Définition d'un ransomware

Un ransomware est un logiciel malveillant qui vise à bloquer l'accès à un système ou à des données, souvent par chiffrement, puis à réclamer une rançon à la victime. (NIST SP 1800-25, CISA)

Comportements caractéristiques (détectables avant les dommages irréversibles)

- Renommage massif de fichiers avec une extension suspecte (.locked, .enc, .crypt...)
- Apparition d'une note de rançon (HOW_TO_DECRYPT.txt)
- Suppression des sauvegardes automatiques du système (points de restauration)
- Détournement d'outils système légitimes pour dissimuler l'attaque
- Suppression massive de fichiers, communications réseau inhabituelles

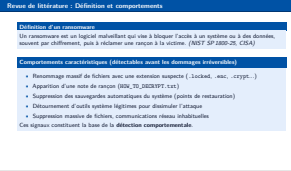
Ces signaux constituent la base de la **détection comportementale**.

RansomShield
└ Revue de littérature

└ Revue de littérature : Définition et comportements

2026-07-06

[DÉFINITION — 3 :45 | 45 sec]
Le NIST définit le ransomware comme un logiciel malveillant qui bloque l'accès aux données — le plus souvent par chiffrement — pour ensuite réclamer une rançon.
Ce qui nous intéresse : ces attaques ne sont pas silencieuses. Elles laissent des traces avant que les dégâts soient irréversibles.
On peut observer : un renommage massif de fichiers avec une extension suspecte comme .locked, la création d'une note de rançon, la suppression des clichés instantanés VSS, ou l'utilisation d'outils système détournés — ce qu'on appelle les LOLBins.
Ce sont précisément ces signaux comportementaux que notre moteur surveille.
→ Mais pourquoi les outils existants ne suffisent-ils pas ?



Solutions existantes

- **Antivirus** : détection par empreintes connues (ClamAV, Windows Defender)
- **SIEM** (centralisation des journaux d'activité) : collecte sans analyse comportementale
- **EDR** (surveillance avancée des terminaux) : CrowdStrike, SentinelOne, Defender XDR

Limites des solutions existantes

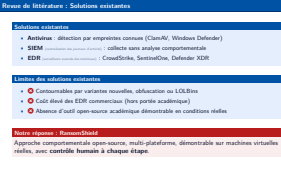
- ❌ Contournables par variantes nouvelles, obfuscation ou LOLBins
- ❌ Coût élevé des EDR commerciaux (hors portée académique)
- ❌ Absence d'outil open-source académique démontrable en conditions réelles

Notre réponse : RansomShield

Approche comportementale open-source, multi-plateforme, démontrable sur machines virtuelles réelles, avec **contrôle humain à chaque étape**.

RansomShield
└─ Revue de littérature

└─ Revue de littérature : Solutions existantes



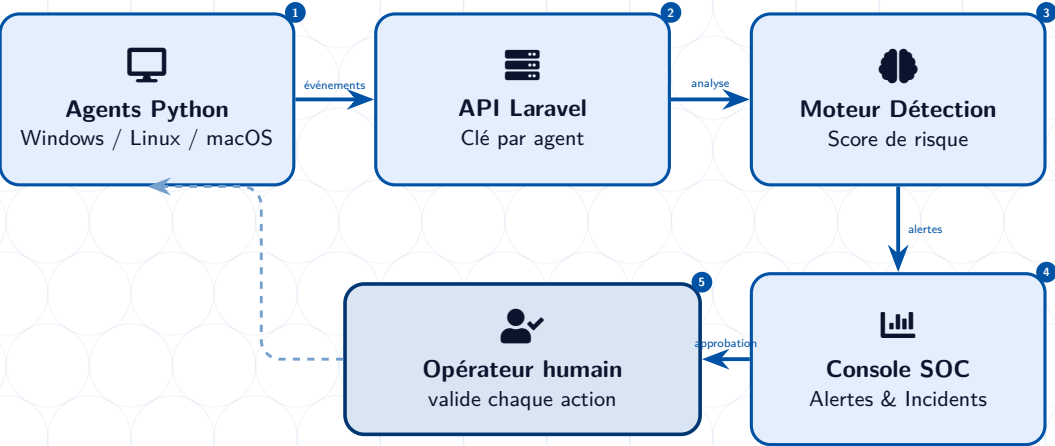
[SOLUTIONS EXISTANTES — 4 :30 | 30 sec]

Les antivirus? Signatures connues — inefficaces sur les variantes nouvelles. Les SIEM? Ils collectent des journaux, sans corrélation comportementale ciblée. Les EDR commerciaux — CrowdStrike, SentinelOne — sont efficaces, mais hors de portée dans un contexte académique.

RansomShield se positionne dans cet espace : approche comportementale, open-source, avec un opérateur humain dans la boucle à chaque décision.

→ Concrètement, comment est-il construit ?

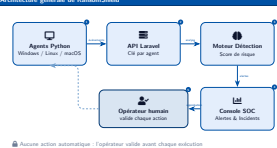
Analyse et Conception



Aucune action automatique : l'opérateur valide avant chaque exécution

2026-07-06

RansomShield
└ Analyse et Conception
└ Architecture générale de RansomShield



[ARCHITECTURE — 5 :15 | 45 sec]
Le flux se lit de gauche à droite, en cinq étapes.
Les agents Python surveillent les fichiers et envoient les événements à l'API Laravel. L'API authentifie et transmet au moteur de détection. Le moteur calcule un score. Quand le seuil est franchi, une alerte est créée et un incident s'ouvre automatiquement. L'opérateur consulte la console SOC et valide chaque action avant qu'elle ne s'exécute.
Règle d'or : aucune action automatique sans validation humaine.
→ Détaillons les quatre composants.

 Agent de surveillance

Observe en temps réel les activités fichiers sur chaque terminal. Les événements sont **conservés localement** : rien n'est perdu même en cas de coupure réseau. Démarrage automatique au lancement.

 Découverte réseau

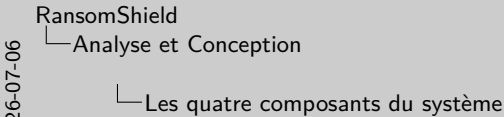
Détecte automatiquement toutes les 5 minutes les nouvelles machines. Aucune n'est intégrée au système sans **accord explicite de l'administrateur**.

 Console de supervision

Tableau de bord actualisé en temps réel. Alertes, incidents, historique des décisions, file d'approbation. Notifications simultanées : web, e-mail, son et webhook.

 Simulateur d'attaques

5 scénarios rejoués sans aucun malware réel, jusqu'à **22 événements**. Chaque test est clairement identifié et nettoyable après démonstration.



[4 COMPOSANTS — 6 :00 | 40 sec]

Premier : l'agent Python — surveille les fichiers en temps réel, conserve une file SQLite locale pour ne rien perdre en cas de coupure réseau. Enrôlement par token à usage unique.

Deuxième : la console SOC — alertes, incidents, file d'approbation, timeline. Notifications sur quatre canaux : web, e-mail, son, webhook.

Troisième : la découverte réseau — scanne les sous-réseaux automatiquement, mais aucun agent ne s'enrôle sans validation manuelle de l'administrateur.

Quatrième : le module de simulation — rejoue jusqu'à 22 événements d'attaque, sans jamais utiliser un vrai malware.

→ Qui interagit avec le système ?

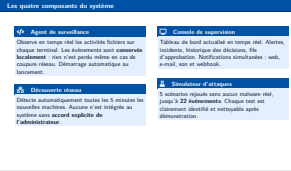
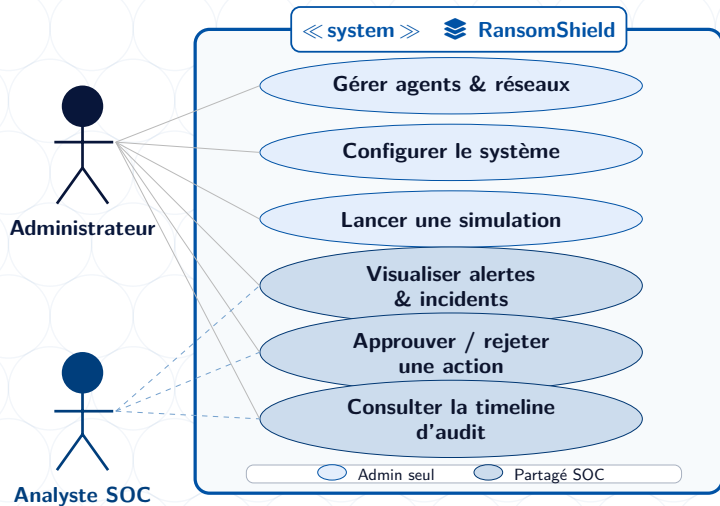


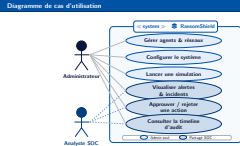
Diagramme de cas d'utilisation



2026-07-06

RansomShield
Analyse et Conception

Diagramme de cas d'utilisation



[USE CASE — 6 :40 | 25 sec]

Deux acteurs, deux rôles distincts.

L'administrateur : il configure, gère les agents, lance les simulations.

L'analyste SOC : il traite l'opérationnel — alertes, incidents, actions. Mais sans accès à la configuration.

Cette séparation garantit qu'un analyste ne peut pas modifier les seuils, et qu'un administrateur ne gère pas les incidents du quotidien.

→ Passons maintenant à la réalisation concrète.

2026-07-06

RansomShield
— Réalisation et Résultats

Réalisation et Résultats

Réalisation et Résultats

[CHOIX TECHNIQUES — 7 :55 | 25 sec]

Les choix techniques ont été guidés par trois critères : portabilité, légèreté, et capacité à démontrer en conditions réelles.

Backend : Laravel 11 et PHP 8.3, base MySQL, API sécurisée par une clé propre à chaque agent.

Agent : Python avec Watchdog, file locale SQLite. Frontend : Chart.js embarqué localement — aucune dépendance CDN externe. Infrastructure : 3 VMs KVM, double authentification activée.

→ Comment l'agent fonctionne-t-il concrètement ?

Fonctionnement de l'agent

- 1 Démarrage et configuration automatique
- 2 Enrôlement sécurisé (jeton à usage unique)
- 3 Surveillance en temps réel des dossiers
- 4 Événements conservés localement
- 5 Transmission sécurisée au serveur central
- 6 Signal de vie toutes les 30 secondes

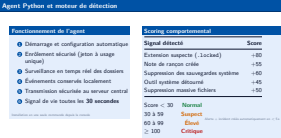
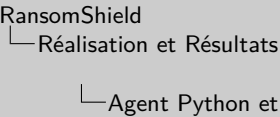
Installation en une seule commande depuis la console

Scoring comportemental

Signal détecté	Score
Extension suspecte (.locked)	+80
Note de rançon créée	+55
Suppression des sauvegardes système	+60
Outil système détourné	+45
Suppression massive fichiers	+50

Score < 30	Normal	Alerte + incident créés automatiquement en < 5 s
30 à 59	Suspect	
60 à 99	Élevé	
≥ 100	Critique	

2026-07-06



[AGENT MOTEUR — 8 :20 | 50 sec]

Au premier démarrage, l'agent s'enrôle avec un token à usage unique — il obtient une clé API permanente.

Ensuite : surveillance des dossiers avec Watchdog, et heartbeat toutes les 30 secondes.

Le moteur calcule un score cumulatif. Exemple concret : un fichier renommé .locked rapporte 80 points.

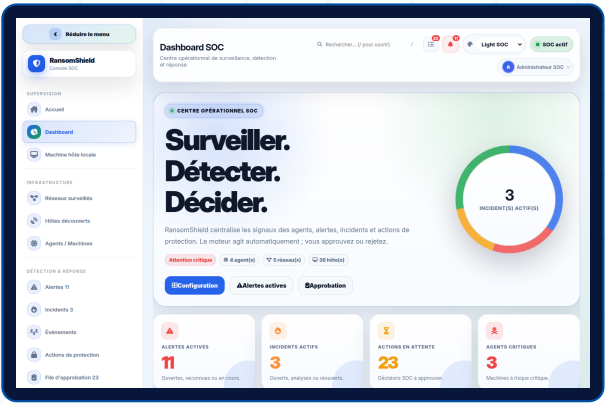
Une note de rançon ajoute 55 points. Total 135 → alerte critique créée et incident ouvert automatiquement.

En moins de 5 secondes.

→ Côté analyste, qu'est-ce que la console offre ?

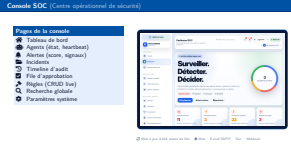
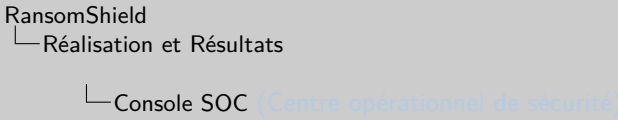
Pages de la console

- Tableau de bord
- Agents (état, heartbeat)
- Alertes (score, signaux)
- Incidents
- Timeline d'audit
- File d'approbation
- Règles (CRUD live)
- Recherche globale
- Paramètres système



Mise à jour AJAX toutes les 30 s Web · E-mail SMTP · Son · Webhook

2026-07-06



[CONSOLE SOC — 9 :10 | 30 sec]

Dix pages fonctionnelles. Le dashboard se rafraîchit toutes les 30 secondes.
Chaque action de protection passe par une file d'approbation : l'analyste valide ou rejette avant toute exécution. Les notifications partent sur quatre canaux simultanés : web, e-mail, son, et webhook.
Vous allez voir tout ça dans quelques instants.
→ Mais d'abord — qu'est-ce que les tests ont donné ?

5 scénarios d'attaque testés

Scénario	Évts	Résultat
Chiffrement basique	7	✓
Kill chain complète	22	✓
Chiffrement massif	18	✓
Exfiltration données	8	✓
LOLBins suspects	5	✓

réseau 10.20.0.0/24

3 VMs KVM |

Résultats obtenus

- ✓ Détection en < 5 secondes (tous scénarios)
- ✓ Aucun événement perdu (file SQLite)
- ✓ Pipeline complet validé bout en bout
- ✓ Rollback isolation réseau fonctionnel
- ✓ 2FA TOTP et API sécurisée (per-agent)

Limite identifiée

Tests conduits sur Linux uniquement. Un attaquant ralentissant son rythme réduit la visibilité.

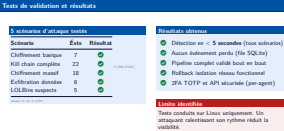
2026-07-06

RansomShield
Réalisation et Résultats

Tests de validation et résultats

[TESTS — 9 :40 | 25 sec]

Cinq scénarios d'attaque, de 7 à 22 événements. Détection en moins de 5 secondes à chaque fois. Zéro perte d'événement. Pipeline validé de bout en bout — de l'événement jusqu'à la timeline d'audit. Une limite que j'assume honnêtement : les tests ont été conduits uniquement sur Linux. Un attaquant qui ralentirait délibérément son rythme resterait moins visible.
→ Maintenant, place à la démonstration.





Démonstration Live

2026-07-06

RansomShield
— Réalisation et Résultats

► Démonstration Live

[DÉMONSTRATION LIVE — 10 :00 | 5 minutes hors chrono]

=== CHECKLIST (dans l'ordre) ===

1. Ouvrir `http://10.20.0.1` — console SOC
 2. Se connecter : identifiants + code 2FA
 3. Vérifier : 3 agents en ligne (voyant vert)
 4. Agents → VM-02 → Lancer simulation → "Kill chain complète" (22 évts)
 5. Dashboard : observer le score monter en temps réel
 6. Alertes : niveau Critique + signaux détectés
 7. Incidents : ouvrir l'incident auto-créé, montrer les détails
 8. File d'approbation : approuver l'isolation réseau
 9. Timeline : tout est horodaté et tracé
- Rester calme. Laisser le temps aux événements d'arriver. Ne pas se précipiter.
→ Revenir à la présentation pour conclure.

Conclusion et Perspectives

2026-07-06

RansomShield
Conclusion et Perspectives

Conclusion et Perspectives

Conclusion

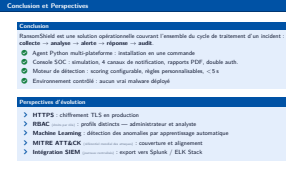
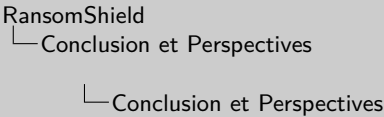
RansomShield est une solution opérationnelle couvrant l'ensemble du cycle de traitement d'un incident : **collecte** → **analyse** → **alerte** → **réponse** → **audit**.

- ✓ Agent Python multi-plateforme : installation en une commande
- ✓ Console SOC : simulation, 4 canaux de notification, rapports PDF, double auth.
- ✓ Moteur de détection : scoring configurable, règles personnalisables, < 5 s
- ✓ Environnement contrôlé : aucun vrai malware déployé

Perspectives d'évolution

- **HTTPS** : chiffrement TLS en production
- **RBAC** (droits par rôle) : profils distincts — administrateur et analyste
- **Machine Learning** : détection des anomalies par apprentissage automatique
- **MITRE ATT&CK** (référentiel mondial des attaques) : couverture et alignement
- **Intégration SIEM** (journaux centralisés) : export vers Splunk / ELK Stack

2026-07-06



[CONCLUSION — après démo | 45 sec]

RansomShield couvre tout le cycle de traitement d'un incident : collecte, analyse, alerte, réponse, audit. Agent multi-plateforme. Console complète. Moteur réactif. Contrôle humain systématique. Ce travail a ses limites : environnement contrôlé, réponses partiellement simulées, tests sur Linux uniquement. Les perspectives sont claires : d'abord le chiffrement HTTPS, puis des rôles utilisateurs distincts, puis à terme du machine learning pour affiner la détection, et une intégration SIEM. Je vous remercie pour votre attention. Je suis à votre disposition pour vos questions.

Merci pour votre attention

2026-07-06

RansomShield
— Conclusion et Perspectives

Merci pour votre attention

[QUESTIONS DU JURY — réponses prêtes]

- Pourquoi Python et pas C ou Go ? Watchdog exploite inotify nativement — CPU minimal, portable Linux/Windows/macOS sans recompilation.
- Comment gérez-vous les faux positifs ? Les seuils sont configurables. L'opérateur humain valide ou rejette chaque action avant qu'elle s'exécute — aucune isolation automatique.
- Pourquoi pas HTTPS ? Réseau LAN contrôlé pour ce projet. Le chiffrement HTTPS est la première perspective pour la production.
- Quelle différence avec un antivirus ? Un antivirus cherche des signatures connues — aveugle aux variantes nouvelles. RansomShield analyse le comportement : renommages, note de rançon, suppression VSS — indépendamment de toute signature.
- Testé sur Windows ? Non — limite assumée. L'agent Python est compatible Windows via Watchdog, mais non testé. C'est une priorité pour la suite.
- La solution passe-t-elle à l'échelle ? Testé sur 3 VMs. L'API Laravel peut monter en charge, mais des tests de performance à grande échelle restent à conduire.

Reformuler la question avant de répondre. Garder les captures d'écran prêtes.